

Module 10: SSH Honeypot Analysis with Kippo

Kayla Teekaram

Overview

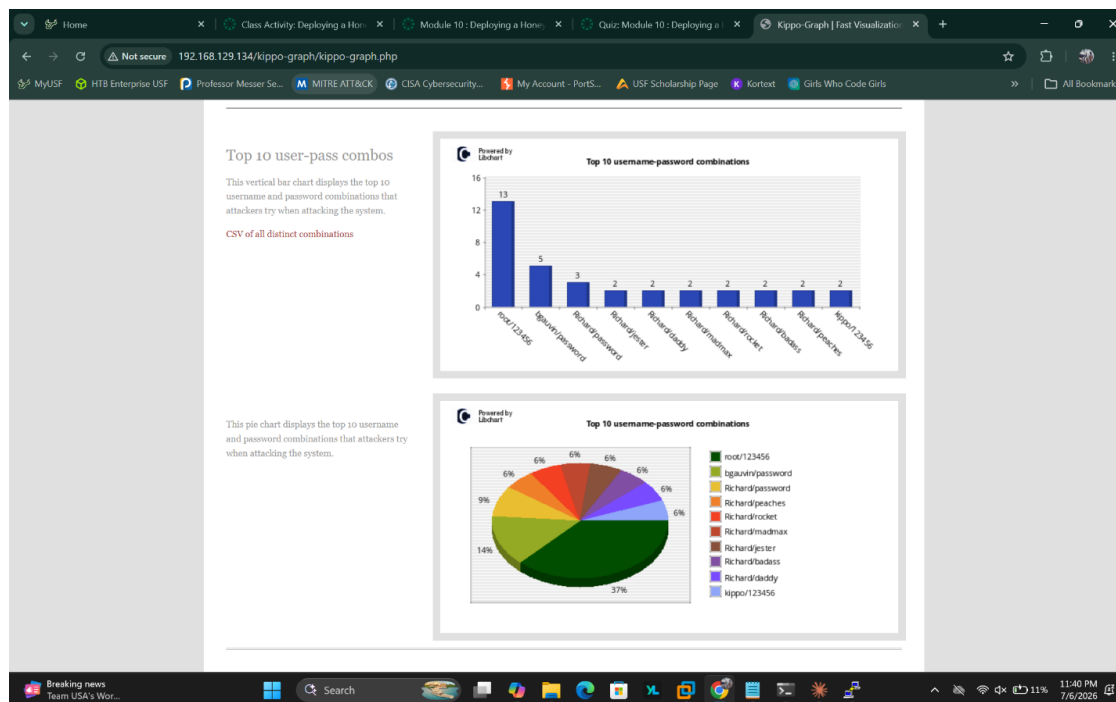
This lab centered on deploying and analyzing Kippo, a medium-interaction SSH honeypot, alongside Kippo-Graph, a web-based visualization tool that parses the honeypot's logs into readable statistics and session playback. The goal was to observe real attacker behavior against an exposed SSH service: what credentials are tried most often, and what an attacker actually does once they believe they've gained shell access.

Environment

Honeypot host: 192.168.129.134, running Kippo (fake SSH service) with Kippo-Graph deployed at /kippo-graph/kippo-graph.php for log visualization. Kippo logs every login attempt — successful or not, since it's a honeypot and “success” is simulated — and records a full TTY transcript of any interactive session, which Kippo-Graph can replay.

Finding 1 — Top Username/Password Combinations

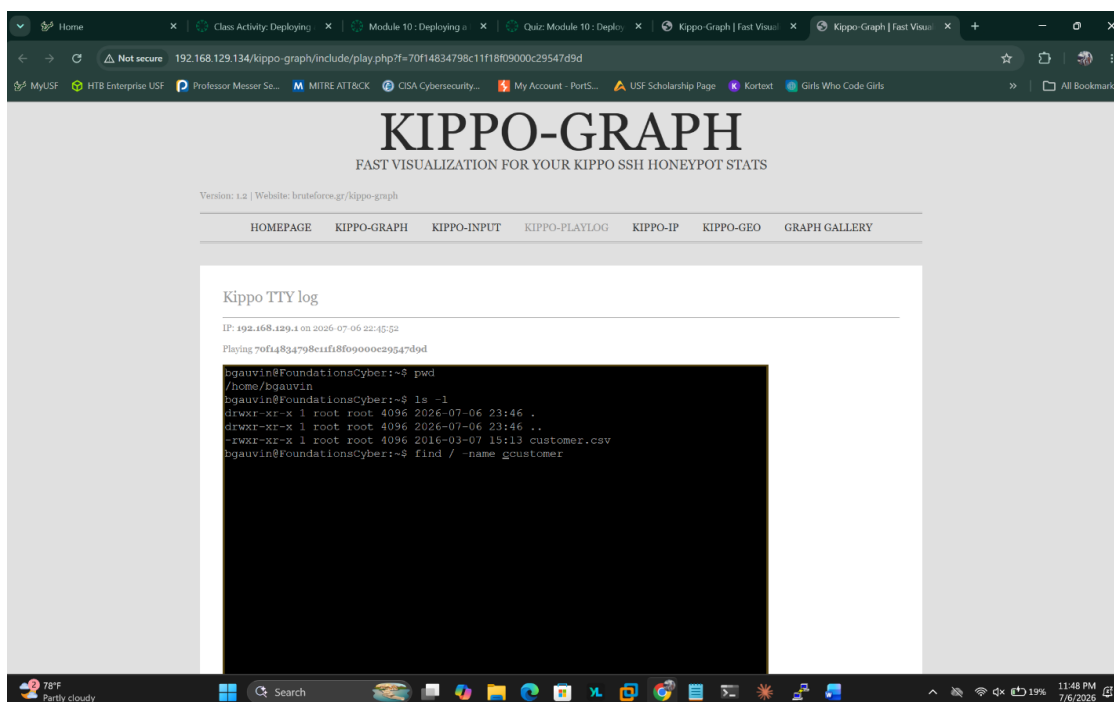
Kippo-Graph's dashboard aggregated the login attempts captured by the honeypot into both a bar chart and a pie chart of the top 10 username/password combinations attackers tried. root/123456 was by far the most common attempt (13 occurrences, roughly 37% of the top-10 sample), consistent with how heavily automated SSH brute-force tools default to “root” with simple numeric passwords. The remaining attempts largely clustered around the username “richard” paired with weak, dictionary-style passwords (password, peaches, rocket, madmax, jester, badass, daddy), alongside a secondary cluster on bgauvin/password and kippo/123456. This distribution is a textbook illustration of why credential-stuffing and brute-force bots remain effective: attackers rely on a small, predictable set of default or weak credentials and simply spray them across large numbers of exposed hosts.



Screenshot 1 — Kippo-Graph's bar and pie charts showing the top 10 username/password combinations attempted against the honeypot, with root/123456 dominating the sample.

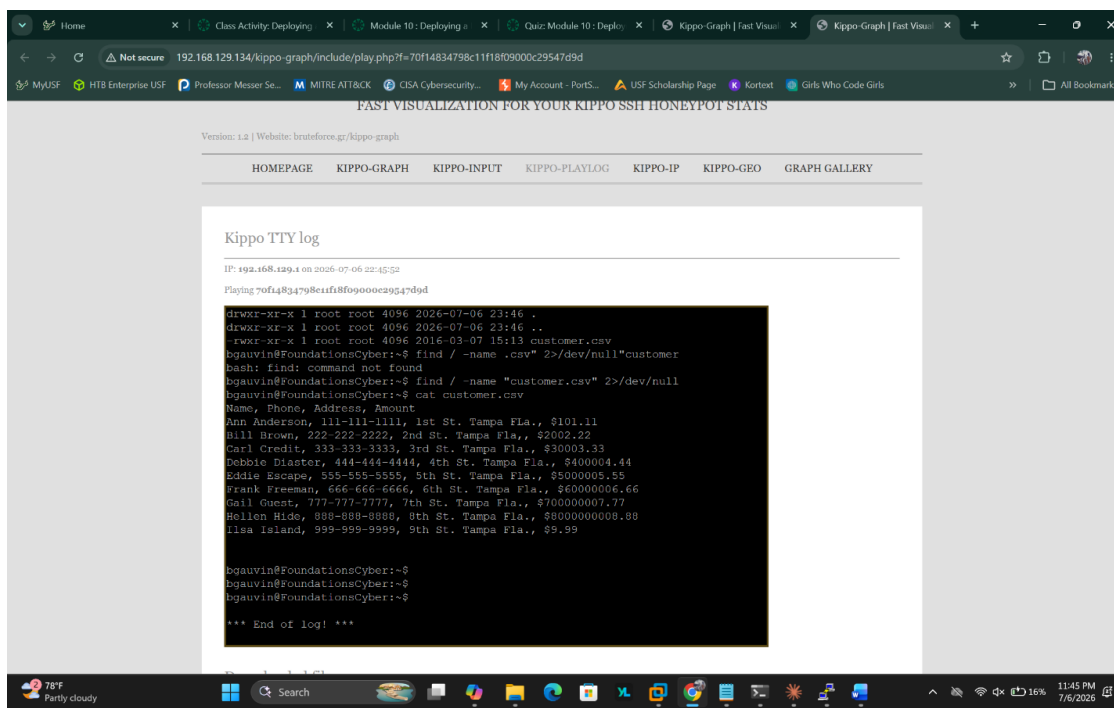
Finding 2 — Session Replay: Attacker Behavior Once “Inside”

Kippo-Graph's TTY log playback feature was used to review a full interactive session from an attacker who had logged in under the simulated account bgauvin. The replay showed a clear, methodical reconnaissance-to-exfiltration pattern. The attacker first confirmed their working directory (pwd) and listed its contents (ls -l), spotting a file named customer.csv sitting in the home directory. They then attempted a find command searching the filesystem for a similarly named file, suggesting they were actively hunting for additional copies or variants of sensitive data beyond what was immediately visible.



Screenshot 2 — Replayed Kippo TTY session showing the attacker listing the home directory and spotting customer.csv, then beginning a filesystem search for related files.

The session continued with a corrected search and direct access to the file. The attacker successfully located and printed the full contents of customer.csv — a file containing names, phone numbers, addresses, and dollar amounts formatted to resemble customer financial records. This is exactly the kind of data a real attacker targeting a compromised server would be looking to exfiltrate.



Screenshot 3 — The attacker locating customer.csv via a filesystem search and then using cat to print its full contents, exposing simulated customer PII and financial data.

Key Takeaways

- Low-interaction honeypots reveal high-value intelligence with minimal risk. Without exposing a real production system, Kippo captured both the scale (which credentials get tried, and how often) and the intent (what an attacker does once they believe they have access) of real-world attack activity.
- Default and weak credentials are still the path of least resistance. The dominance of root/123456 and simple dictionary passwords reinforces the ongoing need for strong password policies and, ideally, disabling password-based SSH authentication entirely in favor of key-based auth.
- Attacker behavior follows a predictable pattern: orient (pwd, ls), search for valuable files (find), then exfiltrate or view (cat). Recognizing this pattern is useful for building detection rules — such as the Snort signatures explored in Module 11 — aimed at catching this exact sequence of behavior on real systems.
- Visualizing honeypot data via Kippo-Graph made it far easier to spot trends across many login attempts than reading raw logs would have, highlighting the value of good tooling in security monitoring workflows.